PHISHING EMAIL ANALYSIS REPORT

Report Title	Phishing Email Analysis (Microsoft Account Credential Harvesting Campaign)
Analyst	SAMSON BUDIGILA
Internship	Future interns
Institution	Institute of Finance Management
Date	February 6, 2026
Sample File	sample2.eml
Classification	PHISHING — HIGH RISK

Contents

1. **Introduction**
2. **Methodology**
3. **Tools Used**
4. **Email Sample Overview**
   - 4.1 Sample Details
   - 4.2 Actual Phishing Email Screenshot [Image 1]
   - 4.3 Header Authentication Results
   - 4.4 MXToolbox Analysis Results Screenshot [Image 2]
5. **Identification of Phishing Indicators**
6. **Email Risk Classification**
   - 6.1 Classification Framework
   - 6.2 Classification Result — sample2.eml
7. **How the Attack Works — Simple Explanation**
   - 7.1 Attack Overview
   - 7.2 Step-by-Step Attack Flow
   - 7.3 Manual Analysis in VS Code Screenshot [Image 3]
8. **Extracted Indicators of Compromise (IOCs)**
9. **VirusTotal / URL Scanner Results**
   - 9.1 VirusTotal Scan Results — Screenshot [Image 4]
10. **Verdict & Recommended Actions**
11. **Prevention Tips for Users**
    - 11.1 How to Spot a Phishing Email
    - 11.2 What to Do If You Receive a Suspicious Email
12. **Do's and Don'ts for Employees**
13. **Long-Term Mitigation Recommendations**
14. **Conclusion**

1. Introduction

Phishing is one of the most prevalent cyber threats facing organizations today. Attackers craft deceptive emails that impersonate trusted entities such as Microsoft, banks, or government agencies to steal credentials, install malware, or commit financial fraud.

This report documents a complete phishing email analysis exercise performed on a captured email sample (sample2.eml). The analysis follows a structured seven-step methodology, from initial collection through to classification, indicator identification, attack explanation, and user-facing prevention guidelines.

Objectives of this report:

1. Collect and document phishing email samples from a controlled environment.
2. Analyze email headers to identify authentication failures and routing anomalies.
3. Inspect sender domains and embedded links for signs of impersonation.
4. Identify all phishing indicators present in the sample.
5. Classify the email risk level using a defined classification framework.
6. Document findings clearly and professionally.
7. Create prevention and awareness guidelines for end users and employees.

2. Methodology

The following seven-step methodology was used to conduct this analysis:

Step	Phase	Description
1	Collect Email Samples	Obtained the phishing email sample (sample2.eml) from Github. Preserved full headers and body content for analysis.
2	Analyse Email Headers	Examined key header fields including From, Reply-To, Return-Path, Received-SPF, DKIM-Signature, and DMARC results to identify authentication failures and spoofing.
3	Inspect Sender Domain & Links	Queried the sender domain (microsoftonline-verify.com) against MXToolbox and DNS records. Expanded the shortened URL (bit.ly) to reveal the true destination.
4	Identify Phishing Indicators	Catalogued all technical and social engineering indicators including typosquatting, urgency language, mismatched link text, and fabricated login activity.
5	Classify Email Risk	Applied a three-tier classification framework (Safe / Suspicious / Phishing) based on the number and severity of indicators identified.
6	Document Findings	Recorded all IOCs, tool outputs, screenshots in this structured report.
7	Prevention & Awareness	Produced practical guidelines, Do's and Don'ts, and user education materials based on the attack techniques observed.

3. Tools Used

The table below lists the tools employed during this analysis. The Description column is left for the analyst to complete.

No	Tool	Purpose
1	MXToolbox	Email header analysis, SPF/DKIM/DMARC record lookup, blacklist check
2	Outlook	Initial receipt and inspection of raw email, header viewing
3	VirusTotal	URL and domain reputation scanning, threat intelligence lookup
4	VS Code	Manual inspection of raw .eml file source and header parsing

4. Email Sample Overview

4.1 Sample Details

Filename	sample2.eml
From Address	noreply@microsoftonline-verify.com
Subject	[Action Required] Unusual sign-in activity on your account
Sender IP	178.238.225.91 (Contabo VPS Germany)
Embedded URL	https://bit.ly/3vF9xKz (URL shortener hiding real destination)
Date	February 6, 2026

4.2 Actual Phishing Email (Screenshot)

The screenshot below shows the actual phishing email as received in the inbox:

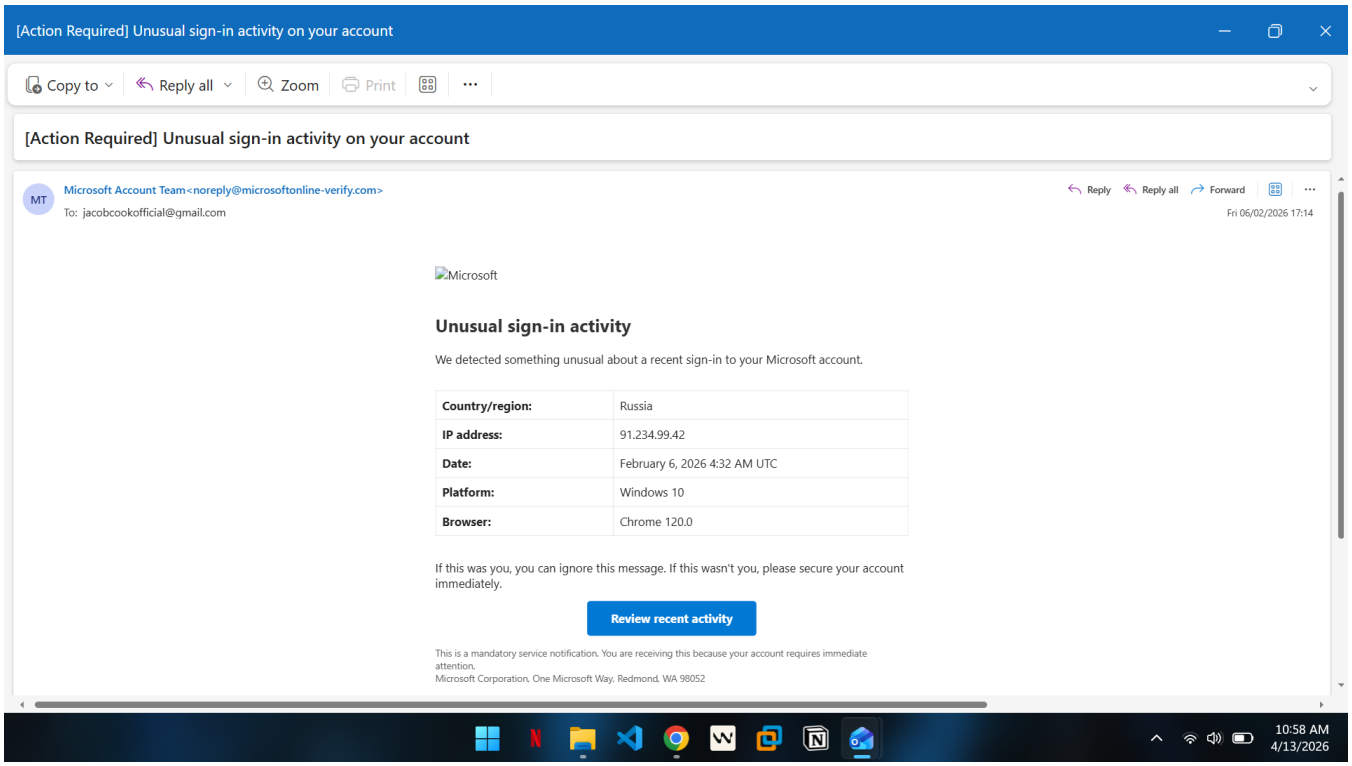


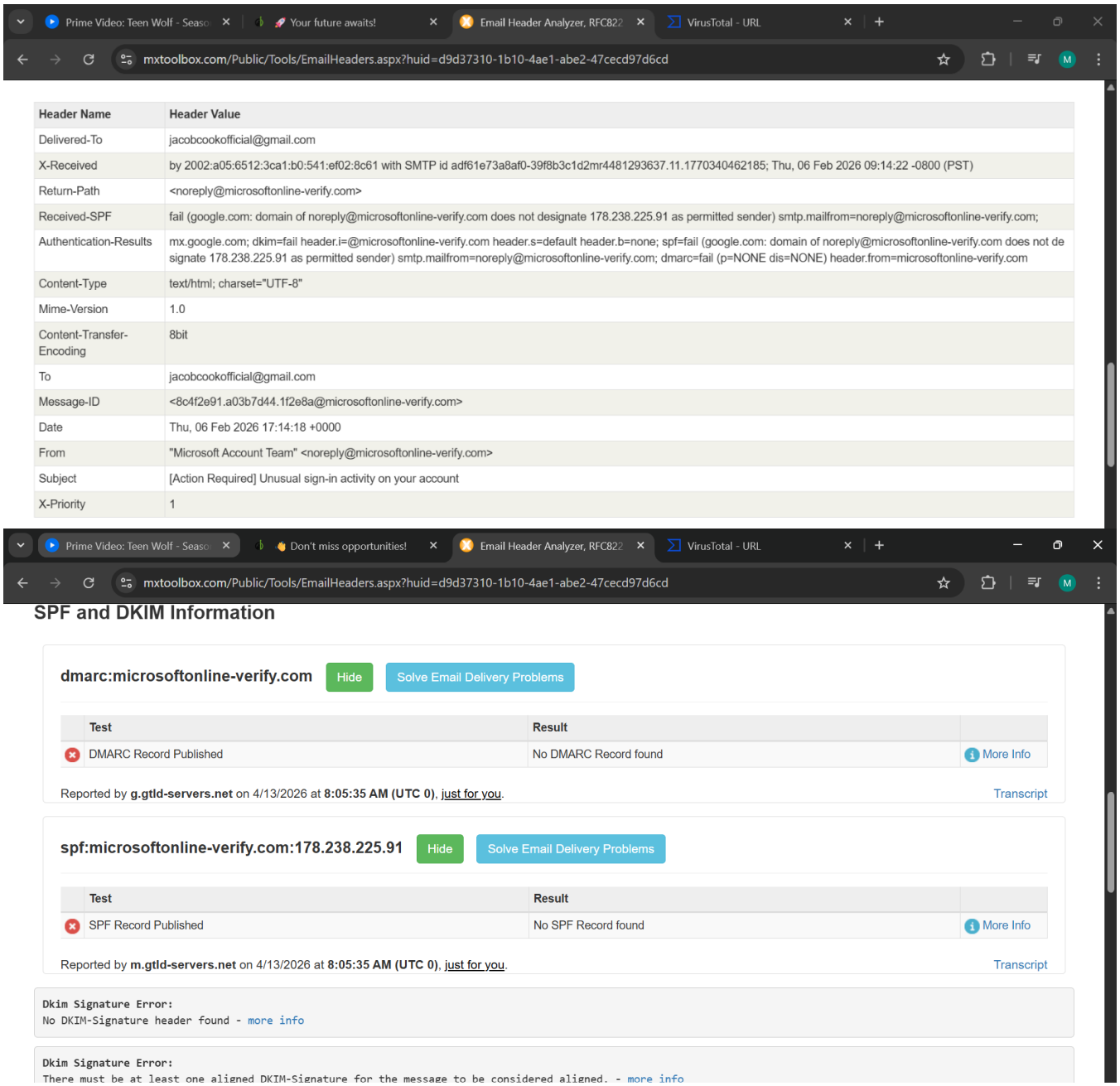
Figure 1: Actual phishing email as received in Outlook

4.3 Header Authentication Results

Authentication Check	Result	Implication
SPF (Sender Policy Framework)	FAIL	Sending IP is not authorised by the domain owner
DKIM (DomainKeys Identified Mail)	FAIL	Email content has not been signed by the claimed domain
DMARC (Domain-based Auth.)	FAIL	No policy alignment — domain spoofing is unchecked

4.4 MXToolbox Analysis Results (Screenshot)

The screenshot below shows the analysis results obtained from MXToolbox:



Header Name	Header Value
Delivered-To	jacobcookofficial@gmail.com
X-Received	by 2002:a05:6512:3ca1:b0:541:ef02:8c61 with SMTP id adf61e73a8af0-39f8b3c1d2mr4481293637.11.1770340462185; Thu, 06 Feb 2026 09:14:22 -0800 (PST)
Return-Path	<noreply@microsoftonline-verify.com>
Received-SPF	fail (google.com: domain of noreply@microsoftonline-verify.com does not designate 178.238.225.91 as permitted sender) smtp.mailfrom=noreply@microsoftonline-verify.com;
Authentication-Results	mx.google.com; dkim=fail header.i=@microsoftonline-verify.com header.s=default header.b=none; spf=fail (google.com: domain of noreply@microsoftonline-verify.com does not de signate 178.238.225.91 as permitted sender) smtp.mailfrom=noreply@microsoftonline-verify.com; dmarc=fail (p=NONE dis=NONE) header.from=microsoftonline-verify.com
Content-Type	text/html; charset="UTF-8"
Mime-Version	1.0
Content-Transfer-Encoding	8bit
To	jacobcookofficial@gmail.com
Message-ID	<8c4f2e91.a03b7d44.1f2e8a@microsoftonline-verify.com>
Date	Thu, 06 Feb 2026 17:14:18 +0000
From	"Microsoft Account Team" <noreply@microsoftonline-verify.com>
Subject	[Action Required] Unusual sign-in activity on your account
X-Priority	1

Figure 2: Analysis results from MXToolbox showing SPF/DKIM/DMARC failures

5. Identification of Phishing Indicators

A total of six primary phishing indicators were identified in this sample. Each is described below with its technical basis and severity rating.

No	Indicator	Technical Detail	Severity
1	Spoofed Sender Domain (Typosquat)	microsoftonline-verify.com mimics the legitimate microsoftonline.com. The "-verify" addition makes the domain look official while pointing to attacker-controlled infrastructure.	Critical
2	SPF / DKIM / DMARC All Fail	All three email authentication mechanisms fail simultaneously. Legitimate Microsoft emails pass all three triple failure is a definitive spoofing indicator.	Critical
3	URL Shortener Hiding Destination	The action button links to https://bit.ly/3vF9xKz. Microsoft never uses URL shorteners in security alerts; legitimate alerts link to account.microsoft.com.	High
4	Urgency & Social Engineering	Subject contains "[Action Required]" and references sign-in from Russia. The X-Priority: 1 header triggers urgency indicators in email clients to bypass rational thinking.	High
5	Fabricated Sign-In Activity Table	The email body shows a fake login attempt from IP 91.234.99.42 (claimed Russia). This information is entirely fabricated to create fear.	High
6	Contabo VPS Hosting	Sending IP (178.238.225.91) resolves to Contabo, a budget VPS provider commonly exploited for phishing inconsistent with Microsoft enterprise infrastructure.	Medium

6. Email Risk Classification

6.1Classification Framework

Classification	Criteria	Recommended Action
SAFE	No suspicious indicators. Passes all authentication checks.	No action required. Deliver to inbox normally.
SUSPICIOUS	1–2 minor indicators. Partial authentication failure.	Quarantine and review. Notify user. Do not click links.
PHISHING	3+ confirmed indicators. Clear impersonation or malicious intent.	Block sender/domain. Quarantine all matching emails. Escalate if user interacted.

6.2 Classification Result for sample2.eml

Risk Classification	PHISHING
Confidence Level	High (6 of 6 indicators confirmed)
Indicators Confirmed	Domain spoofing, SPF/DKIM/DMARC fail, URL shortener, urgency language, fabricated login table, VPS hosting
Immediate Action	Block domain at mail gateway, quarantine all matching emails, notify users
Escalation Required	Yes if any user clicked the link or entered credentials

7. How the Attack Worked

This section explains the attack suitable for awareness training.

7.1 Attack Overview

This is a credential harvesting attack. The attacker's goal is to steal the victim's Microsoft username and password by tricking them into clicking a fake link and logging in on a fraudulent website that looks exactly like the real Microsoft sign-in page.

7.2 Step-by-Step Attack Flow

Step	Phase	What Happens
1	Email Delivery	The attacker sends a carefully crafted email from microsoftonline-verify.com a fake domain designed to look like Microsoft. The email warns of unusual sign-in activity from Russia.
2	Creating Urgency	The subject line includes "[Action Required]" and the email shows a fabricated table with a Russian IP address attempting to access the account. This creates fear and pushes the victim to act without thinking.
3	The Malicious Link	The "Review recent activity" button links to a bit.ly short URL. The victim cannot see the real destination. When clicked, the short URL redirects silently to a fake Microsoft login page controlled by the attacker.

4	Credential Capture	The victim, believing they are on the real Microsoft website, types in their email address and password. The fake page sends these credentials to the attacker, then redirects to the real Microsoft site to avoid suspicion.
5	Account Compromise	The attacker now holds the victim's credentials. They can log in to the Microsoft account, read emails, access OneDrive, or sell the credentials on dark web markets.
6	Lateral Movement	If the same password is reused elsewhere (banking, LinkedIn, cloud storage), the attacker can compromise multiple additional accounts from a single stolen credential.

7.3 Manual Analysis in VS Code (Screenshot)

The screenshot below shows the manual inspection of the raw .eml file using VS Code:

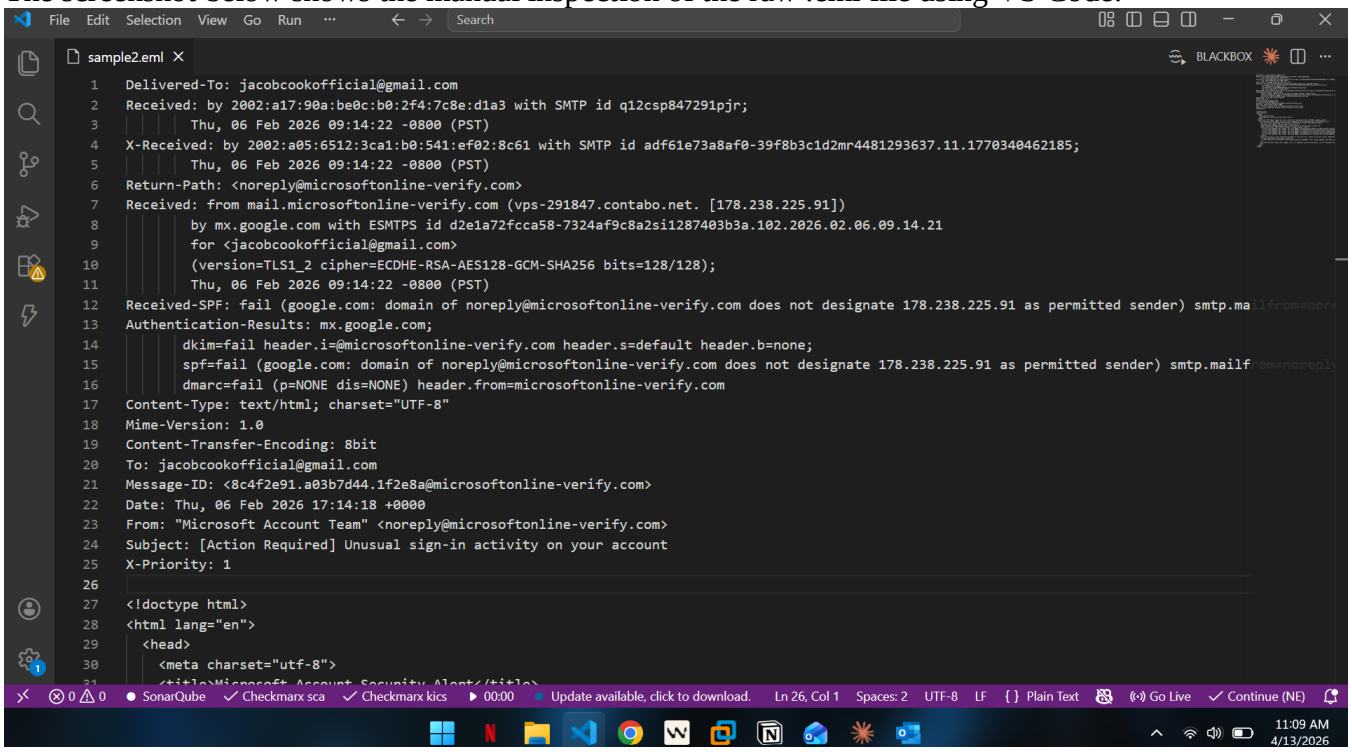


Figure 3: Manual analysis of raw .eml source file using VS Code

8. Extracted Indicators of Compromise (IOCs)

The following IOCs were extracted from the email sample and should be added to blocklists and threat intelligence platforms immediately:

IOC Type	Value	Description
Sender Email	noreply@microsoftonline-verify.com	Typo squat of microsoftonline.com not a Microsoft-owned domain
Domain	microsoftonline-verify.com	Registered to impersonate Microsoft login services. All DNS auth checks fail
Sender IP	178.238.225.91	Contabo VPS (Germany) this is commonly abused for phishing infrastructure
Shortened URL	https://bit.ly/3vF9xKz	URL shortener concealing real phishing destination
Fabricated IP	91.234.99.42	Fake Russian IP displayed in email body to manufacture urgency
Subject Line	[Action Required] Unusual sign-in activity on your account	Standard Microsoft credential phishing lure pattern

9. VirusTotal / URL Scanner Results

URL Scanned	https://bit.ly/3vF9xKz
Domain Pattern	microsoftonline-verify.com matches known typosquat patterns for Microsoft impersonation campaigns
Hosting IP	178.238.225.91 (Contabo) appears in multiple threat intelligence feeds as phishing hosting infrastructure
Assessment	HIGH-CONFIDENCE PHISHING — domain impersonates Microsoft, all authentication fails, URL shortener obscures malicious destination

9.1 VirusTotal Scan Results (Screenshot)

The screenshot below shows the results from the VirusTotal scan of the URL and domain:

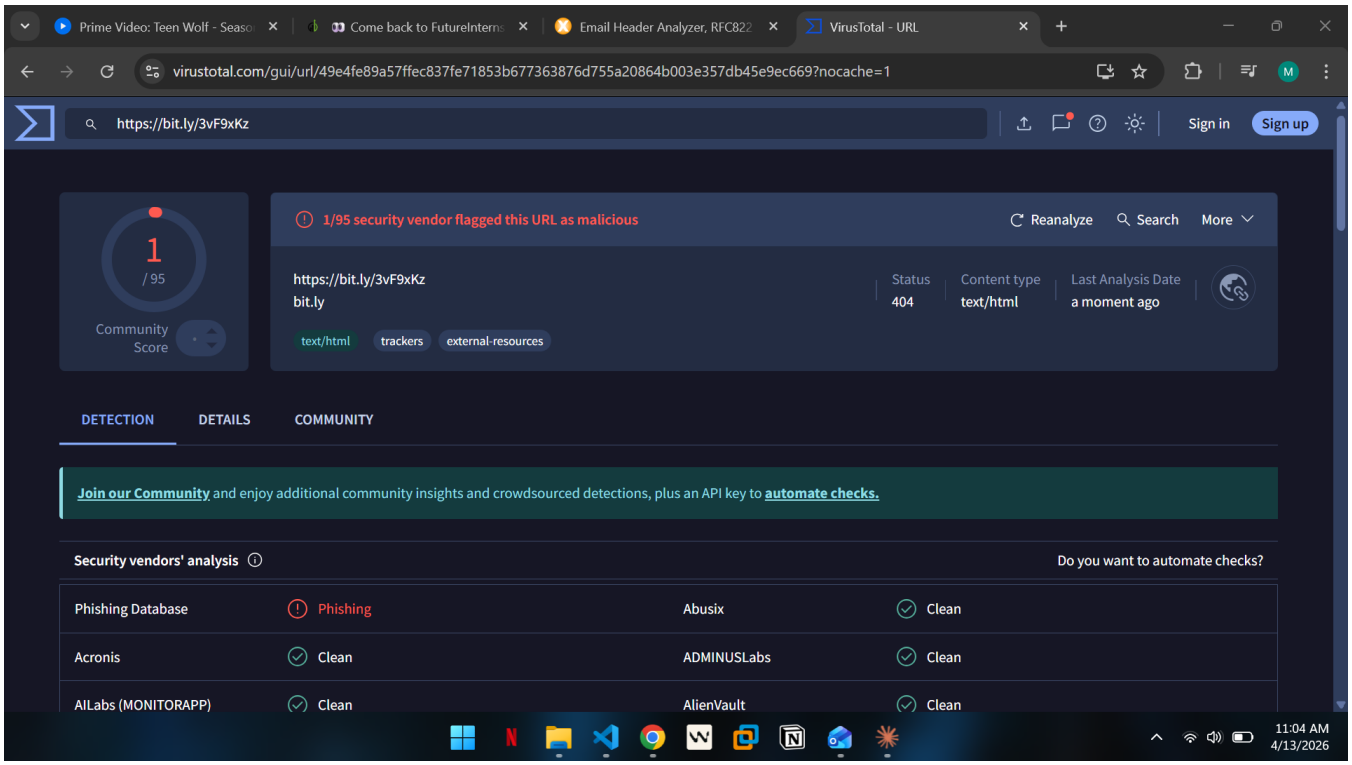


Figure 4: Results from VirusTotal showing domain reputation and threat detections

10. Verdict & Recommended Actions

PHISHING	HIGH RISK

Reason:

1. Domain is a typo squat: microsoftonline-verify.com is not owned or operated by Microsoft.
2. All authentication mechanisms fail: SPF fail, DKIM fail, DMARC fail. Legitimate Microsoft emails pass all three.
3. URL shortener used: Microsoft never uses bit.ly links in security alerts.
4. Attacker-controlled hosting: Contabo VPS is inconsistent with Microsoft enterprise infrastructure.
5. Coordinated social engineering: Fabricated Russian IP, X-Priority: 1, and "[Action Required]" combine to manufacture panic.
6. Template mimicry: Layout, colours, and language closely replicate authentic Microsoft security notifications.

Immediate Recommended Actions

No	Action	Details
1	Block sender domain	Block microsoftonline-verify.com and all subdomains at the mail gateway immediately
2	Quarantine matching emails	Search for and remove all emails from this domain across all user mailboxes organisation-wide

3	Notify users	Alert users: Microsoft security alerts never use URL shorteners or originate from non-microsoft.com domains
4	Escalate if user interacted	If any user clicked the link or entered credentials, escalate to Tier 2 / Incident Response immediately
5	Block IP at perimeter	Add 178.238.225.91 to perimeter firewall blocklist and update threat intelligence feeds

11. Prevention Tips for Users

The following prevention tips are based directly on the attack techniques observed in this sample. They are written for non-technical users.

11.1 How to Spot a Phishing Email

#	**Warning Sign**	**What to Look For**
1	Check the sender's full email address	Look at the actual domain not just the display name. 'Microsoft' as the sender name means nothing if the address ends in @microsoftonline-verify.com.
2	Hover over links before clicking	Hold your mouse over any button or link to see the real URL. If it does not go to microsoft.com or uses a shortener, do not click it.
3	Be suspicious of urgency	Phrases like "[Action Required]" or "Your account will be suspended" are designed to make you act without thinking. Always slow down.
4	Never trust URL shorteners	Legitimate companies like Microsoft, your bank, or your employer will never hide links behind bit.ly. This is always a red flag.
5	Verify through official channels	If you receive a security alert, do not use the link in the email. Open a new browser tab and go directly to account.microsoft.com.
6	Enable Multi-Factor Authentication	Even if attackers steal your password, MFA stops them from accessing your account. Enable it on all important accounts immediately.

11.2 What to Do If You Receive a Suspicious Email

1. Do not click any links or open any attachments.
2. Report the email to your IT or Security team using the official reporting process.
3. Do not forward the email to colleagues this spreads the risk.
4. If you accidentally clicked a link, disconnect from the network immediately and notify IT.
5. Change your password from a safe device if you believe you entered credentials on a suspicious page.

12. Do's and Don'ts for Employees

These guidelines apply to all employees and should be included in ongoing security awareness training.

DOs	DON'Ts
Verify the sender's full email address before taking any action.	Do not trust the display name alone — always check the actual email domain.
Hover over all links to preview the real URL before clicking.	Do not click links in emails that use URL shorteners (bit.ly, tinyurl, etc.).
Navigate to official websites by typing the address directly in your browser.	Do not enter login credentials on any page reached through an email link.
Enable Multi-Factor Authentication (MFA) on all work and personal accounts.	Do not reuse the same password across multiple accounts.
Report any suspicious email to your IT/Security team immediately.	Do not forward suspicious emails to colleagues or share their contents.
Keep your operating system, browser, and antivirus software up to date.	Do not open unexpected attachments, even from people you know.
Attend security awareness training sessions provided by your organisation.	Do not ignore security alerts or assume it will not happen to you.
Use a password manager to create and store strong, unique passwords.	Do not write passwords on paper or store them in unencrypted files.

13. Long-Term Mitigation Recommendations

Based on the attack techniques observed, the following long-term controls are recommended for organizational deployment:

#	Control	Category	Detail
1	Enforce MFA on all Microsoft 365 accounts	Identity	Conditional access policies requiring MFA prevent account compromise even when credentials are stolen
2	Advanced phishing filter at mail gateway	Email Security	Block emails from domains containing 'microsoftonline' that are not microsoftonline.com
3	Real-time URL reputation filtering	Network Security	Block access to URL shorteners and perform URL reputation checks before delivery
4	DMARC policy enforcement (p=reject)	Email Security	Implement DMARC reject policy to prevent spoofing of your own domain
5	Quarterly security awareness training	Human Layer	Conduct phishing simulation exercises quarterly and train users to report suspicious emails
6	Incident response plan for phishing	Governance	Document and rehearse the response process for users who click phishing links or submit credentials

14. Conclusion

This analysis confirms that email sample (sample2.eml) is a high-confidence phishing attack designed to steal Microsoft account credentials. The attack combines six corroborated indicators including domain spoofing, complete authentication failure, URL obfuscation through a shortener, and coordinated social engineering tactics.

The classification is PHISHING HIGH RISK. Immediate action should be taken to block the sender domain, quarantine all matching emails, and notify affected users.